

Security Testing Report using DVWA

1. Introduction

This project was conducted in a controlled laboratory environment using DVWA (Damn Vulnerable Web Application) installed on Kali Linux. The objective was to identify, analyze, and understand common web application vulnerabilities included in the OWASP Top 10.

2. Tools Used

- Kali Linux
- DVWA (Damn Vulnerable Web Application)
- Apache Web Server
- MariaDB
- Burp Suite Community Edition
- Firefox Browser

3. SQL Injection (SQLi)

Objective

To demonstrate how improper handling of user input can lead to unauthorized database access.

Description

SQL Injection occurs when user input is directly incorporated into SQL queries without proper validation or parameterization.

Observation

The application accepted user-supplied input and returned database records. The behavior demonstrated how insecure query construction can expose sensitive information.

Impact

- Unauthorized data disclosure
- Authentication bypass
- Data modification
- Database compromise

Mitigation

- Prepared Statements
- Parameterized Queries
- Input Validation
- Least Privilege Access Control

Screenshots

- SQLi-1: Vulnerable Page
 - SQLi-2: Normal Query Result
 - SQLi-3: Vulnerability Demonstration
-

4. Cross-Site Scripting (XSS)

Objective

To understand the risks associated with unsanitized user input rendered in web pages.

Description

Cross-Site Scripting allows malicious scripts to execute in a victim's browser.

Types Tested

- Stored XSS
- Reflected XSS

Impact

- Session Hijacking
- Credential Theft
- Website Defacement
- Malicious Redirection

Mitigation

- Output Encoding
- Input Validation
- Content Security Policy (CSP)
- Secure Frameworks

Screenshots

- XSS-1: Stored XSS Page
 - XSS-2: Reflected XSS Page
 - XSS-3: Demonstration Result
-

5. Cross-Site Request Forgery (CSRF)

Objective

To understand how authenticated users can unknowingly perform unintended actions.

Description

CSRF attacks exploit the trust relationship between a user's browser and a web application.

Impact

- Unauthorized Password Changes
- Unauthorized Transactions
- Account Manipulation

Mitigation

- Anti-CSRF Tokens
- SameSite Cookies
- Re-authentication for Sensitive Actions
- Origin Validation

Screenshots

- CSRF-1: Vulnerable Page
- CSRF-2: Request Demonstration
- CSRF-3: Protection Mechanism

6. Conclusion

The project successfully demonstrated multiple OWASP Top 10 vulnerabilities within a controlled DVWA environment. The exercises highlighted the importance of secure coding practices, proper input validation, and defense-in-depth security controls.